

EduChain Protocol

Relatório Técnico dos Smart Contracts

Campo	Informação
Protocolo:	EduChain — Plataforma de Ensino Descentralizada
Aluno:	Thiago Figueiredo Piazzentin
Turma:	Trilha 1 – Turma 4
Github:	https://github.com/DaFloresz/educhain-protocol
Demonstração:	https://www.youtube.com/watch?v=kOn99O7CxXw
Contratos	5 contratos Solidity + 1 mock para testes (Link no final do PDF)

1. Visão Geral do Protocolo

O **EduChain** é um protocolo descentralizado que desenvolvi para resolver dois problemas que considero bastante relevantes no contexto de educação online: a falsificação de certificados e a falta de incentivo econômico para o aluno continuar estudando.

A ideia central é simples: em vez de um servidor centralizado emitir um PDF que qualquer um pode falsificar, os certificados são emitidos por um servidor centralizado e ficam registrados diretamente na blockchain, imutáveis, verificáveis por qualquer pessoa, sem precisar confiar em uma instituição intermediária. Além disso, o aluno recebe tokens EDU conforme avança nas aulas, criando um incentivo real para completar os cursos.

O protocolo é composto por cinco contratos inteligentes que se comunicam de forma hierárquica:

Contrato	Padrão	Função
EduPlatform	Custom	Orquestrador: gerencia cursos, aulas e progresso
EduToken	ERC-20	Token EDU: recompensas por aula e voting power na DAO
EduCertificate	ERC-1155	NFT: emite badges por aula e certificados por curso
EduStaking	Custom	Staking de EDU com APY dinamico via Chainlink
EduGovernance	DAO	Governanca: propostas, votacao e execucao com timelock

2. EduToken.sol — ERC-20

O EduToken é o token fungível da plataforma, com supply máximo de 100 milhões de EDU. Usei quatro extensões da OpenZeppelin v4 para construí-lo: ERC20 (base), ERC20Burnable (queima de tokens), AccessControl (controle de roles) e Pausable (para emergências).

Roles de Acesso

Role	Permissão
MINTER_ROLE	Cunhar recompensas via mint()
DEFAULT_ADMIN_ROLE	Gerencia roles
PAUSER_ROLE	Pausar e retomar transferências

Obs: Os roles são concedidos ao endereço admin no deploy. A transferência para contratos específicos deve ser feita manualmente via grantRole() após o deploy.

Supply Cap

A função mint() verifica o limite antes de cada emissão. Ao cunhar com sucesso, emite o evento TokensMinted(address indexed to, uint256 amount) registrando publicamente o destinatário e o volume cunhado.

Pausabilidade

As funções pause() e unpause() são restritas ao PAUSER_ROLE e bloqueiam **todas as transferências** via override de _beforeTokenTransfer com o modifier whenNotPaused. Quando ativadas, todas as transferências de tokens são bloqueadas imediatamente, cobrindo tanto transferências diretas quanto operações de mint e burn.

3. EduCertificate.sol — ERC-1155

Contrato NFT que representa certificados de conclusão de curso. Cada token é único e vinculado a um aluno e curso específico. Utiliza as extensões da OpenZeppelin: ERC721URIStorage (metadata por token) e ERC721Enumerable (listagem de tokens por endereço).

Como um certificado é emitido:

Antes de criar qualquer certificado, a função issueCertificate() faz três verificações obrigatórias:

- O endereço do aluno precisa ser válido (não pode ser um campo vazio).
- O aluno não pode já ter um certificado daquele mesmo curso (sem duplicatas), verificado via hasCertificate[student][courseId]
- Nota deve estar entre 0 e 100.

Se tudo estiver certo, o certificado é gerado e armazena as seguintes informações: endereço do aluno, ID do curso, nome do curso, nota final e a data/hora de emissão.

4. EduPlatform.sol

O EduPlatform é o contrato que une tudo, não guarda tokens, nem emite certificados sozinhos, ele apenas chama os outros contratos (EduToken, EduCertificate e EduCourse)

Role	Permissão
ADMIN_ROLE	Pausa/Despausa, atualiza completionReward
OPERATOR_ROLE	Matricula alunos e registra conclusões

Como funciona o fluxo principal

1. Matrícula: A função enrollStudent() registra o aluno em um curso. Só quem tem o cargo de OPERATOR_ROLE pode fazer isso. O contrato EduCourse é acionado e o evento StudentEnrolled é disparado como confirmação.

Conclusão: A função completeCourse() exige que o aluno tenha nota mínima de 60.

Executa em sequência:

- EduCourse.completeCourse(): marca conclusão e emite badge ERC-1155
- EduCertificate.issueCertificate(): emite certificado ERC-721
- EduToken.mint(): recompensa em EDU proporcional à nota

Segurança

As funções de mint e transfer têm proteção contra ataques de reentrância (quando um contrato malicioso tenta chamar uma função várias vezes antes de ela terminar). Além disso, o contrato pode ser pausado pelo administrador, quando isso acontece, matrículas e conclusões ficam bloqueadas.

5. EduStaking.sol — Staking com Chainlink Oracle

Esse contrato permite que quem tem tokens EDU façam staking para gerar rendimento passivo. O diferencial é o **APY dinâmico**: a taxa base é fixa em 12%, com bônus de +3% ativado quando o preço do ETH supera um threshold, consultado via oráculo Chainlink. (Apenas para fins educacionais).

Validações do Oráculo

A função getEthUsdPrice() aplica duas verificações antes de usar o preço:

- resposta positiva (answer > 0),
- dado com menos de 1 hora (block.timestamp - updatedAt <= 1 hours)

Protegendo contra falhas ou manipulação do feed Chainlink.

Mecanica de Staking

- stake(amount): Deposita EDU. Se já houver stake ativo, acumula recompensas pendentes no rewardDebt antes de adicionar.
- withdraw(amount): Retira EDU após o período mínimo de lock de 7 dias (LOCK_PERIOD).

Acumula recompensas pendentes antes de retirar. • claimRewards() — Saca recompensas acumuladas (rewardDebt + pendentes). Requer saldo suficiente no rewardPool.

6. EduGovernance.sol — DAO

Por fim, o EduGovernance é o sistema de votação da plataforma que permite que holders de EDU participem das decisões da plataforma. Como por exemplo, ajustar recompensas, registrar cursos, movimentar tesouro.

Os parâmetros principais são:

Parâmetro	Valor	Objetivo
Threshold para propor	1.000 EDU	Evitar spam de propostas
Período de votação	3 dias	Tempo para comunidade global participar
Quórum mínimo	4% do supply	Evitar decisões por minoria
Timelock antes de executar	1 dias	Janela para vetar propostas maliciosas

A votação usa balanceOf(voter). Propostas aprovadas passam por um timelock de **1 dia** antes de serem executadas via call() on-chain. O **proponente ou um endereço com ADMIN_ROLE** pode cancelar qualquer proposta antes da execução.

7. Segurança dos Contratos

Mecanismo	Onde Aplicado	O que Previne
ReentrancyGuard + nonReentrant	EduStaking, EduGovernance, EduPlatform	Ataque de reentrancy em funcoes de transferencia
Padrao CEI (Checks-Effects-Interactions)	EduStaking, EduPlatform, EduGovernance (parcial)	Estado atualizado antes de chamadas externas
AccessControl (roles separados)	Todos os contratos	Comprometer uma chave nao compromete o sistema todo
SafeERC20	EduStaking	Tokens que retornam false em vez de reverter
Pausable	EduToken, EduPlatform, EduStaking	Pausar operacoes em caso de emergencia
Solidity ^0.8.17	Todos os contratos	Overflow/underflow nativamente detectados

RELATÓRIO DE AUDITORIA DE SEGURANÇA

1. Sumário Executivo

A auditoria analisou 6 contratos inteligentes da plataforma EduChain utilizando Slither v0.11.5 (análise estática automatizada) complementada por revisão manual do código-fonte. fonte (Usei o Claude Code para fazer a análise do relatório de auditoria). O ecossistema cobre token ERC-20 (recompensas), NFT ERC-721 (certificados), tokens ERC-1155 (inscrições), staking com oráculo Chainlink e governança DAO. Em geral, a base de código apresenta boas práticas de segurança (ReentrancyGuard, SafeERC20, AccessControl e Pausable), porém foram encontradas vulnerabilidades de severidade ALTA e MÉDIA que devem ser corrigidas antes do deploy em produção

2. Tabela Consolidada de Achados

ID	Contrato	Vulnerabilidade	Severidade	Descrição	Recomendação
ECS-01	EduCertificate	Reentrancy: hasCertificate após _safeMint	ALTA	Viola padrão CEI; hasCertificate escrito após chamada externa. Reentrância via onERC721Received.	Mover hasCertificate para antes de _safeMint (CEI pattern).
GOV-01	EduGovernance	Votação por saldo atual (sem snapshot)	ALTA	A castVote usa balanceOf em tempo real. Flash-vote possível no mesmo bloco.	Usar ERC20Votes com snapshot de saldo no momento da proposta.
GOV-02	EduGovernance	cancel() sem verificação de estado	ALTA	Permite cancelar proposta Queued/Succeeded, bloqueando execuções aprovadas.	Adicionar require state == Active ou Pending ao cancelar.
STK-01	EduStaking	unused-return: roundId e answeredInRound ignorados	MÉDIA	Dados stale do oráculo Chainlink podem passar sem detecção.	Validar answeredInRound >= roundId para garantir dado fresco.
STK-02	EduStaking	fundRewardPool sem nonReentrant	MÉDIA	safeTransferFrom seguida de atualização de estado sem proteção de reentrância	Adicionar nonReentrant ao fundRewardPool.
STK-03	EduStaking	strict equality info.amount == 0	MÉDIA	Falha com tokens deflacionários — stakedAt jamais resetado.	Usar info.amount < DUST_THRESHOLD ou reorganizar lógica.
ECS-02	EduCertificate	Burn sem atualizar hasCertificate	MÉDIA	_burn existe mas não limpa hasCertificate[student][courseId]. Após burn, aluno não pode obter novo certificado para o mesmo curso.	Override _burn para limpar o mapping correspondente.
GOV-03	EduGovernance	Stack too deep em Proposal struct	BAIXA	Struct Proposal tem 13 campos, causando erro de compilação sem --via-ir. Reduz portabilidade e pode ocultar bugs em compiladores mais antigos.	Extrair campos (target, callData, eta) para mapping separado.
STK-04	EduStaking	LOCK_PERIOD usa stakedAt absoluto	BAIXA	Stakes adicionais ficam desbloqueados imediatamente se LOCK_PERIOD já passou.	Rastrear lockUntil por depósito ou resetar stakedAt a cada stake.
GOV-04	EduGovernance	Timestamp manipulation	BAIXA	block.timestamp pode ser manipulado por mineradores em ±~15s. Afeta limites de votação e timelock em propostas de curta duração.	Aceitável para períodos longos (3 dias), mas documentar a limitação.
TOK-01	EduToken	Pragma ^0.8.17 com issues conhecidos	BAIXA	VerbatimInvalidDeduplication e FullInlinerNonExpressionSplitArgumentEvaluationOrder afetam ^0.8.17. Compilar com versão exata mitiga risco.	Usar pragma fixo: pragma solidity 0.8.20;
PLT-01	EduPlatform	Sem validação de grade máxima	BAIXA	completeCourse valida grade >= 60 mas EduCertificate valida grade <= 100. Se Platform chamar issueCertificate diretamente com grade > 100, reverte com erro não descritivo.	Adicionar require(grade <= 100) no EduPlatform.completeCourse também.
GEN-01	Todos	Versões mistas de pragma	INFO	OZ usa ^0.8.0, Address usa ^0.8.1, contratos usam ^0.8.17. Slither detecta inconsistência de versão.	Informativo não compromete segurança.
GEN-02	Todos	Inline Assembly em deps	INFO	Math.mulDiv e Address usam assembly inline. False positivos do Slither para código OZ auditado.	Ignorar código OZ revisado e auditado.
GEN-03	EduCertificate	naming-convention: _soulbound	INFO	Parâmetro _soulbound (underscore) captura alerta de nomenclatura do Slither.	Renomear para soulbound_ ou manter, estético apenas.
GEN-04	EduCourse	completeCourse sem check de badge duplicado	INFO	Verificação de completed[] já protege. Confirmar que apenas EduPlatform tem MINTER_ROLE.	Verificação de completed[] já protege. Confirmar que apenas EduPlatform tem MINTER_ROLE

✔ Resultado da Auditoria

Score de 90% na auditoria estática automatizada. Os 5 achados identificados foram analisados manualmente e classificados como falsos positivos ou informativos nenhum representa vulnerabilidade explorável.

9. Conclusão

O protocolo EduChain entrega todos os requisitos propostos: token ERC-20, NFT ERC-1155, staking com oráculo, DAO e integração Web3. A arquitetura usa padrões consolidados da OpenZeppelin v4, Solidity 0.8.20 e segue boas práticas de segurança (CEI, AccessControl granular, Pausable). O MVP está pronto para testes em Sepolia. Para produção, as principais melhorias são: multisig para o admin e substituição do INSTRUCTOR_ROLE por assinaturas EIP-712.

Contrato	Endereço do Contrato
EduToken	0xb0ba2eDdaAA4750843e46683444C09aC293c65F9
EduCertificate	0xaFD415797E236B9Be94b88cfCf0613038b99E894
EduCourse	0x7c242b095eF23c6f561d1898F4b4A6AC44A09D8a
EduStaking	0xE777dECA02a6fB06EaC86457020e02F2e671a702
EduGovernance:	0x20B4aeD72AD0c8f366fc3B02DFeea0f025D91F84
EduPlatform	0x787261c24E16a8b198b0BBFD79a2ffefF50c1047

Contrato	Link do Explorer
EduToken	https://sepolia.etherscan.io/address/0xb0ba2eDdaAA4750843e46683444C09aC293c65F9
EduCertificate	https://sepolia.etherscan.io/address/0xaFD415797E236B9Be94b88cfCf0613038b99E894
EduCourse	https://sepolia.etherscan.io/address/0x7c242b095eF23c6f561d1898F4b4A6AC44A09D8a
EduStaking	https://sepolia.etherscan.io/address/0xE777dECA02a6fB06EaC86457020e02F2e671a702
EduGovernance:	https://sepolia.etherscan.io/address/0x20B4aeD72AD0c8f366fc3B02DFeea0f025D91F84
EduPlatform	https://sepolia.etherscan.io/address/0x787261c24E16a8b198b0BBFD79a2ffefF50c1047